Documento de Entrega - Grupo 124

Documento de entrega
Projeto: Oficina API SOAP Challenger 1

Identificacao do grupo
Grupo: 124
Participante: CESAR DE MOURA ALMEIDA
E-mail: cesaralmeida268@gmail.com
Username no Discord: C.M.A BR

Links de entrega
Documentacao e artefatos:
https://github.com/Cesar-Almeida/soat_tech_challenger_1/tree/main/outputs
Repositorio: https://github.com/Cesar-Almeida/soat_tech_challenger_1

Conteudo
1. Informacoes do grupo e links
2. Escopo da analise de seguranca
3. Vulnerabilidades encontradas
4. Plano de correcao recomendado

Data da analise: 31/08/2026. Este relatorio apresenta uma analise estatica manual do codigo-fonte e das configuracoes do MVP. Ele nao substitui testes de invasao, revisao de infraestrutura ou auditoria de producao.

Relatorio de Seguranca

Escopo da analise

Foram revisados os arquivos de configuracao da aplicacao, a configuracao de seguranca JWT, os controladores HTTP, a configuracao H2 e os arquivos Docker. O foco foi identificar riscos de autenticacao, autorizacao, segredos, exposicao de dados e operacao em ambiente de producao.

Controles positivos identificados

- Autenticacao JWT nas rotas administrativas.
- Senha de login processada com BCrypt.
- Expiracao de token configurada em 120 minutos.
- Validacao de CPF/CNPJ, placa e dados de entrada.
- Consulta publica da OS condicionada ao documento do proprietario.
- Regra de estoque impede saldo negativo.

Resumo de riscos

Critico: segredo JWT padrao exposto em codigo/configuracao.
Alto: credenciais administrativas fixas no codigo-fonte.
Alto: console H2 habilitado com usuario padrao e senha vazia.
Medio: ausencia de limitacao de tentativas no login.
Medio: ausencia de TLS e de cabecalhos de seguranca na aplicacao.
Medio: qualquer JWT valido recebe privilegio administrativo.

Relatorio de Seguranca

Vulnerabilidades encontradas - parte 1

V1 - Segredo JWT padrao exposto (Critico)
Evidencia: app.jwt.secret esta definido em application.yml e tambem possui valor padrao no docker-compose.yml. Impacto: quem obtem o repositorio ou imagem pode assinar tokens falsos e assumir acesso administrativo. Correcao: remover o valor padrao, usar cofre de segredos ou variavel de ambiente obrigatoria, rotacionar o segredo e invalidar tokens anteriores.

V2 - Credencial administrativa fixa (Alto)
Evidencia: o usuario admin e a senha admin123 estao definidos no SecurityConfiguration. Impacto: a credencial e previsivel e pode ser explorada por qualquer pessoa com acesso ao codigo ou conhecimento do padrao. Correcao: persistir usuarios, armazenar hashes de senha no banco, criar o primeiro administrador por mecanismo seguro e remover credenciais de demonstracao.

V3 - Console H2 habilitado e sem senha (Alto)
Evidencia: h2.console.enabled esta ativo e o datasource usa usuario sa sem senha. Impacto: se o console ou a porta da aplicacao forem expostos, ha risco de leitura, alteracao ou exclusao de dados. Correcao: desabilitar o console fora do perfil local, usar banco gerenciado em producao, credenciais fortes e regras de rede restritivas.

Relatorio de Seguranca

Vulnerabilidades encontradas - parte 2

V4 - Sem protecao contra forÃ§a bruta (Medio)
Evidencia: o endpoint de login nao possui rate limit, bloqueio temporario ou registro de falhas. Impacto: tentativas automatizadas podem descobrir senhas fracas. Correcao: aplicar limitacao por IP e usuario, bloqueio progressivo, CAPTCHA quando aplicavel e monitoramento de eventos de autenticacao.

V5 - Transporte e cabecalhos nao configurados (Medio)
Evidencia: nao ha configuracao de HTTPS, HSTS, Content-Security-Policy ou outros cabecalhos no projeto. Impacto: quando publicado sem proxy seguro, trafego e token podem ser interceptados. Correcao: terminar TLS em proxy reverso, redirecionar HTTP para HTTPS e configurar cabecalhos de seguranca adequados.

V6 - Autorizacao sem perfis granulares (Medio)
Evidencia: o filtro JWT concede ROLE_ADMIN a todo token valido. Impacto: nao existe separacao entre atendente, mecanico e administrador; um usuario autenticado recebe privilegio excessivo. Correcao: incluir roles como claims assinadas, validar usuario ativo e permissao no servidor e aplicar autorizacao por rota e operacao.

Plano de acao priorizado
1. Antes de publicar: corrigir V1, V2 e V3.
2. Na proxima iteracao: implementar V4 e V6.
3. No processo de deploy: implementar V5 e migrar de H2 para banco de producao.
4. Depois das correcoes: executar teste de invasao, SAST e analise de dependencias.